

# Ширяево Поле

Как я нашёл флаг через массовое переприсвоение ролей

Как я нашёл JWT: (1) Открыл сайт, зарегистрировался логин 'test'. (2) Открыл DevTools (F12) → Application → Local Storage. (3) Нашел переменную `ftblchk_token` с JWT. (4) Декодировал payload (вторая часть) через base64 в консоли: `atob('...')`. (5) Увидел JSON с моей ролью `fan` и `commentator_id: null`.

## Стартовый токен (декодирован через base64)

Декодировал payload и увидел: HS256, роль `fan`, без привязки к комментатору. Это токен зрителя, к закрытым эндпоинтам не пройдёт.

## Три попытки атаки

Рассмотрел три способа получить привилегированный токен. Первые два не сработали, третий открыл дверь.

|                  |                                         |            |
|------------------|-----------------------------------------|------------|
| 01 · БРУТФОРС    | rockyou.txt (14M) + типовые секреты     | не найден  |
| 02 · ALG:NONE    | Токен с <code>{"alg":"none"}</code>     | 401, отбит |
| 03 · MASS ASSIGN | role + commentator_id в PATCH /users/me | сработало  |

## Попытка 1: Брутфорс HS256-секрета

Написал Python-скрипт, перебирающий HMAC-SHA256 для каждого слова словаря. Результат: `rockyou.txt` (14M строк) — нет совпадений за 65 сек. Кастомные словари — тоже нет. Этот путь закрыт.

## Попытка 2: Подделать алгоритм

Собрал токен с `{"alg":"none"}` и ролью `commentator` без подписи. Отправил на `/reveal` — 401 Invalid token. Сервер явно ограничивает допустимые алгоритмы. Уязвимость не в криптографии.

## Разбор JavaScript кода приложения

Скачал основной бандл `index-*.js` и найденный в нём `CommentatorRoutes-*.js`. Там вся логика раскрытия исхода. В `CommentatorRoutes` нашёл функцию расшифровки: `key = SHA256(reversed_nickname | matches | nonce | matchId)`, потом AES-GCM decrypt.

## Попытка 3: Эскалация роли через PATCH

Создал новый аккаунт (fan). Заметил: есть PATCH /api/v1/users/me для профиля. Клиент отправляет только display\_name и bio. Что если отправить больше? Отправил: {"display\_name":"Test","bio":"hi","role":"commentator","commentator\_id":12} — 200 OK. Сервер принял и записал мне роль commentator и commentator\_id: 12 (это комментатор матча №67). Массовое переприсвоение полей (mass assignment) — уязвимость.

## Получить новый JWT с новой ролью

База обновлена, но старый токен помнит role: fan. POST /auth/refresh выдал новый JWT с role: commentator, commentator\_id: 12, валидно подписанный сервером.

## Вызов защищённых эндпоинтов

POST /commentator/matches/67/reveal → 200: {"nonce": "aENqu4QP8WIGuQB6udC5yqPI", "iv": "zOolgF/dDeWKD4UR", "data": "0Jr9fF+mdhr6..."}.

GET /commentator/12/profile → 200: {"id":12, "nickname":"Quackmaster", "matches":67}.

## Расшифровать исход

Формула ключа (из JS): keyMaterial = reversed\_nickname|matches|nonce|matchId.  
Компоненты: nickname="Quackmaster"→"retsamkcauQ" (из профиля), matches=67 (из профиля), nonce="aENqu4QP8WIGuQB6udC5yqPI" (из reveal), matchId=67.  
Декодирование: iv из base64→12 байт, data из base64→шифротекст. key = SHA256(keyMaterial), plaintext = AESGCM(key).decrypt(iv, data, None) → flag{fr0m\_4shes\_m0sc0w\_r3b00ts\_1812}

## Анализ

Корневая причина: PATCH /api/v1/users/me не валидирует список редактируемых полей. Сервер принимает и записывает любые поля из тела запроса — mass assignment. Любой зритель может выставить себе роль commentator. После обновления в базе сервер выпускает новый JWT с новыми данными, подписанный корректно.

Почему не сработали другие методы: Брутфорс — секрет не входит в словари. alg:none — сервер ограничивает алгоритмы на верификации.

Как исправить: Явный allow-list полей на PATCH (только display\_name, bio). Смена ролей только через отдельный админ-эндпоинт. Проверка роли на всех commentator-GET, не только на /reveal.